Haunted Candy Chefs: Web Exploit - Beginner

Creator: Adrian R. Anaya Points: 00

Description

Node.js/Express web application backed by MongoDB. It simulates a Halloween-themed candy vault guarded by a ghostly chef. The application exposes two endpoints: POST /search — Search candies by JSON filter POST /seance — Authenticate as a ghost to access the crypt Both endpoints pass user-controlled JSON directly into MongoDB queries without type validation, making them vulnerable to NoSQL operator injection.

Github Path: Capture_The_Flame_2027/Web_Exploit/haunted-candy-chefs

Prompt

Rumor spreads through the village every October — the Candy Crypt opens at midnight, and whoever can outwit the Headless Chef walks away with the Golden Candy. Many have tried. Most leave with empty bags and colder souls.

Tonight, it's your turn.

Start Here: http://<localHost>:8000
Flag format: flame{...}

Hints

1. The crypt speaks JSON. When you whisper your password, what if you whispered something other than a string?
2. The crypt doesn't compare your password to a fixed value — it matches it against a query. What if the password itself was a query?
3. The Headless Chef left a clue in his candy. Search the crypt's stash — the ingredients are not just for show.

Solution 1 NoSQL Injection via $ne

1. Send a password as a MongoDB operator object instead of a string
2. { "username": "headless_chef", "password": { "$ne": null } }
3. Why it works: $ne: null matches any non-null password.
    a. Sets the password flag as true and gives the flag

Solution 2 Password Recovery via Candy Ingredients

1. The Headless Chef's signature candy — The Golden Candy — has an ingredients list whose first words spell his password
2. Find the Golden Candy
    a. In the search you can set the {“id”:4 } or {chef: 'The Headless Chef'}
3. Once you find the correct chef/Candy
4. You would look at the ingredients list, take the first word of each ingredient
5. Paste in as the password with _ in between.

```
Blood Sausage, Moonlight, Rising Soul
       ↓         ↓          ↓
     blood   + moon   + rising
       ↓
  blood_moon_rising
```

Flag

flame{tr1ck_0r_tr34t_n0sql_styl3}